

1. Question

A new information security policy has been developed to comply with recent regulatory requirements. Which of the following should be the NEXT step in ensuring effective implementation of the policy?

- A. Train all employees on the new policy.
- B. Publish the policy on the company intranet.
- C. Integrate the policy into the existing security framework.
- D. Conduct an awareness campaign for stakeholders.

Answer: C. Integrate the policy into the existing security framework.

Explanation: Integrating the policy into the existing security framework ensures it is aligned with current practices, making implementation more effective. Training and awareness are crucial but should come after integration.

2. Question

During a quarterly review, the CISO finds that several security initiatives have missed their deadlines. What should the CISO do FIRST to address this issue?

- A. Implement stricter deadlines for future projects.
- B. Re-evaluate the KPIs for these initiatives.
- C. Conduct a root cause analysis for the missed deadlines.
- D. Adjust the project management approach to be more flexible.

Answer: C. Conduct a root cause analysis for the missed deadlines.

Explanation: A root cause analysis helps identify why deadlines are being missed, allowing the CISO to implement corrective measures. Adjusting the project management approach or KPIs should be based on the findings of this analysis.

3. Question

An organization's security program is not meeting its strategic objectives. What is the MOST effective way to align the security program with organizational goals?

- A. Update the security policy to match the organization's goals.
- B. Develop new KPIs to measure security program performance.
- C. Conduct a gap analysis between the security program and business goals.
- D. Increase the security program budget.

Answer: C. Conduct a gap analysis between the security program and business goals.

Explanation: A gap analysis will help identify the misalignment between the security program and organizational goals, providing insights for adjustment. Updating policies or KPIs should follow the identification of specific gaps.

4. Question

Which of the following is the BEST indicator that a security awareness program is effective?

- A. Increased number of reported security incidents.
- B. Decrease in the number of phishing emails received.

- C. High participation rate in training sessions.
- D. Reduction in the number of user-related security breaches.

Answer: D. Reduction in the number of user-related security breaches.

Explanation: The ultimate goal of a security awareness program is to reduce user-related security incidents. A decrease in such breaches indicates that employees are more aware and applying their training.

5. Question

A company has implemented a new information security strategy. Six months later, the security manager notices that key performance indicators (KPIs) show minimal progress. What should be the FIRST action to address this?

- A. Increase the frequency of performance reviews.
- B. Reassess the relevance and appropriateness of the KPIs.
- C. Allocate additional resources to the strategy.
- D. Revise the information security strategy.

Answer: B. Reassess the relevance and appropriateness of the KPIs.

Explanation: KPIs must be relevant and capable of accurately measuring progress. If they do not reflect true performance, reassessment is necessary before making further adjustments.

6. Question

A security manager has identified a metric that measures the time to patch critical vulnerabilities. Which of the following would BEST help in reducing this metric?

- A. Increase the number of staff responsible for patching.
- B. Develop a policy for patch management timelines.
- C. Implement automated patch management tools.
- D. Conduct more frequent vulnerability assessments.

Answer: C. Implement automated patch management tools.

Explanation: Automation can significantly reduce the time to deploy patches, ensuring quicker response times to vulnerabilities.

7. Question

The board has requested a dashboard to monitor the effectiveness of the security program. Which metric would provide the BEST indication of the program's success?

- A. Number of security awareness training sessions conducted.
- B. Average time taken to detect a security incident.
- C. Number of firewalls deployed across the organization.
- D. Amount spent on security initiatives.

Answer: B. Average time taken to detect a security incident.

Explanation: The time to detect incidents is a critical metric that reflects the effectiveness of detection capabilities, directly impacting the overall success of the security program.

8. Question

A security policy requires quarterly reviews of access rights for critical systems. During an audit, it was found that reviews were only conducted semi-annually. What is the MOST important action to take?

- A. Update the policy to reflect the current practice.
- B. Implement stricter compliance monitoring for reviews.
- C. Train system owners on policy requirements.
- D. Review and adjust the scope of critical systems.

Answer: B. Implement stricter compliance monitoring for reviews.

Explanation: To ensure adherence to the policy, compliance monitoring should be improved to detect and correct deviations.

9. Question

After implementing a new cybersecurity policy, a large number of policy exceptions are requested. What does this indicate, and what action should be taken?

- A. The policy is too restrictive; adjust it.
- B. The policy was not communicated properly; increase training.
- C. Exceptions should be denied to enforce policy compliance.
- D. Review the exception requests to identify common patterns and adjust the policy.

Answer: D. Review the exception requests to identify common patterns and adjust the policy.

Explanation: A large number of exceptions suggests potential flaws or impracticalities in the policy. Reviewing the requests allows for adjusting the policy to better meet practical needs while maintaining security objectives.

10. Question

Which of the following would BEST demonstrate the effectiveness of a newly implemented data loss prevention (DLP) program?

- A. Reduction in the number of DLP-related alerts.
- B. Increase in the number of incidents blocked by the DLP system.
- C. Decrease in incidents of sensitive data leaving the network.
- D. Faster response time to DLP alerts.

Answer: C. Decrease in incidents of sensitive data leaving the network.

Explanation: The main goal of a DLP program is to prevent data leakage. A reduction in incidents directly shows the program's effectiveness.

11. Question

An organization is implementing a strategy to achieve ISO 27001 certification. Which of the following should be done FIRST to ensure a successful implementation?

- A. Conduct an internal audit.

- B. Identify and assess organizational risks.
- C. Develop detailed information security policies.
- D. Appoint an ISO 27001 project lead.

Answer: B. Identify and assess organizational risks.

Explanation: Risk assessment is fundamental in ISO 27001, guiding the creation of policies and controls. It is the first step in aligning with the standard's requirements.

12. Question

Which of the following is the MOST critical factor in ensuring the successful implementation of an information security program?

- A. High budget allocation.
- B. Senior management support.
- C. A comprehensive awareness program.
- D. Well-defined policies and procedures.

Answer: B. Senior management support.

Explanation: Senior management support is crucial for ensuring the necessary resources, authority, and organizational commitment to the security program.

13. Question

An organization's security program includes a KPI for reducing the time taken to contain security incidents. Which metric would BEST support this KPI?

- A. Number of incidents detected per month.
- B. Average time to resolve incidents.
- C. Percentage of incidents escalated to management.
- D. Average time from incident detection to containment.

Answer: D. Average time from incident detection to containment.

Explanation: This metric directly measures the speed of incident containment, aligning with the goal of reducing containment time.

14. Question

Which of the following actions would BEST help measure the effectiveness of an organization's security strategy?

- A. Reviewing the number of security incidents reported.
- B. Comparing security expenditure against industry benchmarks.
- C. Evaluating the impact of security incidents on business operations.
- D. Assessing user feedback on security policies.

Answer: C. Evaluating the impact of security incidents on business operations.

Explanation: The ultimate measure of a security strategy's effectiveness is how well it protects business operations and minimizes the impact of incidents.

15. Question

To ensure the ongoing effectiveness of an information security program, which of the following should be done on a regular basis?

- A. Re-write all security policies annually.
- B. Conduct regular risk assessments and update controls accordingly.
- C. Rotate security responsibilities among different team members.
- D. Implement new technologies as they become available.

Answer: B. Conduct regular risk assessments and update controls accordingly.

Explanation: Regular risk assessments ensure that the program remains aligned with evolving threats and business objectives, allowing for continuous improvement.